

System Acquisition, Development and Maintenance Policy

Ver. 4.0

Last Revision: June 16, 2025

Document Control:

Document Title:	System Acquisition, Development and Maintenance Policy
Version	4.0
Classification	Internal
Effective Date	16-June-2025
Author	Srikanth P
Reviewer	KranthiKiran K
Approver	Satnam Singh

Revision History:

Version No.	Date of Effectiveness	Change Description	Author	Reviewed By	Approved By
V1.0	22-Aug-2020	Initial Draft	ISMS Team	Satnam Singh	Atul Gambhir
V1.1	5-Aug-2021	Disclaimer Added	ISMS Team	Satnam Singh	Atul Gambhir
V2.0	31-Jan-2022	Aligned with ISMS Requirements	Seema Aggarwal	Satnam Singh	Atul Gambhir
V2.0	30-Jan-2023	Reviewed but no changes are made	ISMS Team	David Trafford & Karim Faith	Jeremy Slater T
V3.0	19-June-2023	Update to reflect new company name Innova Solutions	ISMS Team	Kranthi Katti, Dawn Middleton	Faith Karim
V4.0	17-Jun-2024	Updated policy to reflect - ISO27001-2022 clauses and content.	Srikanth P	KranthiKiran K	Lakshmi Narasimhan Gopalan
v4.0	16-June-2025	Reviewed and no changes are made	Srikanth P	KranthiKiran K	Satnam Singh

Table of Contents

Overview	4
Purpose.....	4
ISO Controls Coverage	5
Policy	5`
Policy Compliance.....	8
Disclaimer.....	9

Overview

Information Security's intentions for publishing a System Acquisition, Development and Maintenance Policy (SADMP) are not to impose restrictions that are contrary to Innova Solutions Inc.'s established culture of openness, trust, and integrity. Information Security is committed to protecting Innova Solutions Inc.'s employees, partners, and the company from illegal or damaging actions by individuals, either knowingly or unknowingly.

Effective security is a team effort involving the participation and support of every Innova Solutions Inc. employee and affiliate who deals with information and/or information systems. It is the responsibility of every mobile device user to know these guidelines, and to conduct their activities accordingly.

Purpose

The purpose of this policy is to ensure information security is designed and implemented within the development lifecycle of information systems.

Scope

This policy is directed towards Innova Solutions Inc.'s development, test and operational computing facilities and all officials associated with Innova Solutions Inc. systems. It includes:

- New system or software implementations including but not limited to:
 - Any new initiative for acquisition of COTS application/Freeware for use in Innova Solutions Inc.
 - In-house or outsourced development of customized application (s), specifically for use in Innova Solutions Inc.
 - Modification of existing application software for version upgrade, feature or privilege enhancement, or other similar activities.
 - Development of scripts for system administration, maintenance, automated backup, other similar activities.
- To control access and protect the confidentiality, integrity and availability of the information processed by or stored in these applications.
- To test the security posture of both the new and the existing applications.

For all the Changes listed below, Refer Change Management Procedure:

- Customizations and modifications to systems or software, and
- Upgrades to existing systems or software.

ISO Controls Coverage

ISO 27001:2022 – 5.8- Information security in project management

- 8.26- Application security requirement
- 8.25- Secure development lifecycle
- 8.32- Change Management
- 8.27- Secure system architecture and engineering principles
- 8.31- Separation of development, test, and production environments
- 8.30- Outsourced development
- 8.29- Security testing in development and acceptance
- 8.33- Test Information

Policy

Security requirements of information systems

Information security in project management

- Information security requirements are identified when introducing new applications/ systems or making enhancements to existing applications/ systems.
- System requirements are taken from business users based on the needs, and information security requirements are identified, documented and approved by head of department.

Application Security Requirements

- Information involved in application services passing over public networks are protected from fraudulent activity, contract dispute and unauthorized disclosure and modification.
- Adequate security controls are put in place to ensure the confidentiality, integrity and availability of such information.
- Information involved in application service transactions are protected to prevent incomplete transmission, misrouting, unauthorized message alteration, unauthorized disclosure, unauthorized message duplication or replay.
- A secure communication channels are setup between all involved parties for application services transactions.
- Protocols used to communicate between all involved parties are secured.

Security in development and support processes

Secure development lifecycle

- Rules for the development of software and systems are established and applied to developments within the organization.
- Secure coding standards are considered and where relevant mandated for use.
- Developers are trained in their use and testing and code review to verify their use.
- Adequate and appropriate backups are taken to ensure availability in case of a disruption.

Change Management

- Changes to systems within the development lifecycle are controlled using formal change control procedures.
- Any changes to an application system/data need to be justified by genuine business need and implemented based on formal change requests authorized by the management.
- Changes are appropriately tested and approved before being implemented in the production environment.
- New releases / patches pertaining to the operating system are tested before being implemented in the production environment.
- Innova Solutions Inc. review the application control and integrity to ensure that they have not been compromised by the operating platform changes.
- It ensures that notification of operating system changes is provided in time so that appropriate tests and reviews are performed before implementation.
- Changes or modifications for vendor supplied software packages are adequately controlled and limited to personnel involved in implementation of the change / modification based on appropriate approvals.
- If changes are necessary, previous version(s) of the software are retained as a contingency measure in case a rollback is required.
- All changes are fully tested and documented.

Secure system architecture and engineering principles

- Principles for engineering secure systems are established, documented, maintained and applied to any information system implementation efforts.
- The established principles are applied, wherever applicable, to outsourced information systems through the contracts and other binding agreements.

Security principles and applicability: The security principles provide a foundation upon which a more consistent and structured approach to the design, development, and implementation of IT security capabilities can be constructed for the information systems. These principles have been defined around the life-cycle planning phases i.e., around the following:

- **Initiation Phase:** During the initiation phase, the need for a system is expressed and the purpose of the system is documented.
- **Development/Acquisition Phase:** During this phase, the system is designed, purchased, programmed, developed, or otherwise constructed. This phase often consists of other defined cycles, such as the system development cycle or the acquisition cycle. Activities include determining security requirements, incorporating security requirements into specifications and obtaining the system. Code review is performed by authorized person other than the developer.

- **Testing/Staging Phase:** During testing/staging phase, the system is tested by performing unit testing, integration testing and security testing. User acceptance testing is performed as per the project requirement. Required use cases, test cases and relevant documentation to be referred by the teams to provide the testing sign-off.
- **Implementation/Deployment Phase:** During implementation, the system is tested and installed or fielded. Activities include installing/turning on controls, certification, and accreditation.
- **Operation/Maintenance Phase:** During this phase, the system performs its work. Typically, the system is also being modified by the addition of hardware and software and by numerous other events. Activities include security operations and administration, operational assurance, and audits and monitoring.
- **Disposal Phase:** The disposal phase of the IT system life cycle involves the disposition of information, hardware, and software. Activities include moving, archiving, discarding or destroying information and sanitizing the media.

In addition to these principles following points need to be considered with respect to application security:

- Input/Output Validation Controls
- Authentication & Authorization
- Session Management
- Secure Configurations & Patch Updates
- Access Control
- Cryptographic Practices
- Exception Handling
- Logging & Monitoring
- Data Protection & Integrity
- Communication Security
- Database Security
- File Management
- Memory Management
- Application Availability and Redundancy
- Code Review
- Application Security Assessments

Separation of development, test and production environments

- Innova Solutions Inc. assess risks associated with individual system development effort and established secure development environment for specific system development. The development, test and production environments need to be properly segregated, any exceptions to be signed off by appropriate authority.

Outsourced development

- In case of outsourced development, arrangements pertaining to licensing, code ownership and intellectual property rights are documented in the contract between the organization and the third-party vendor.

System security testing

- Any new information processing system internally developed or purchased are tested before accepting for implementation in the production environment to ensure that they satisfy business policies/rules of the organization and regulatory and legal prescriptions/requirements.

System Acceptance testing

- Acceptance criteria are defined, and tests are conducted to validate the criteria.
- System acceptance testing include testing of information security requirements and adherence to secure system development practices. Tests are performed in a realistic test environment to ensure that the system will not introduce vulnerabilities to organization's environment and that tests are reliable.

Test Information

Protection of test data

- Use of production data for testing is prohibited.
- Separate authorization required each time for operational information is copied to a test application system.
- Operational information erased from a test application system immediately after the testing is complete.
- The copying and use of operational information are logged to provide an audit trail.
- Strict access controls are implemented in the test system to prevent unauthorized access of test data.

Policy Compliance

Compliance Measurement

Compliance with this policy is mandatory for all the employees of Innova Solutions Inc. and it is to be reviewed periodically. Compliance will be measured by the internal or external audits.

Exceptions

There are no exceptions to this policy.

Non-Compliance

Any individual or a committee found to be not complying with the requirements specified in the policy is bound to accept consequences specified in Disciplinary Actions Specific Procedure.

Disclaimer

Company's Absolute Right to Alter or Abolish the Policy

Innova Solutions Inc. reserves the right in its absolute discretion to abolish the policy and dissolve it at any time or to alter the terms and conditions. Such discretion may be exercised any time, before; during or after the policy year is completed.